Everything old is new again: Cookies for APIs

Bearer token authentication is extremely common for APIs, but as with everything in tech, the landscape is constantly evolving. One area that has seen a lot of change is the process of securing SPAs like React, Angular, and Blazor WASM. The advice for some years was to use the Authorization code with PKCE grant (https://www.rfc-editor.org/rfc/rfc8252#section-6), but the big problem with this pattern is that the bearer tokens for calling the API are ultimately stored in the browser.

An alternative pattern has emerged recently: the Backend for Frontend (BFF) pattern. In this approach, you have a traditional ASP.NET Core application (the backend), which hosts the Blazor WASM or other SPA application (the frontend). The main job of the ASP.NET Core application is to handle OpenID Connect authentication, store the bearer tokens securely, and set an authentication cookie, exactly like a traditional web app.

The frontend app in the browser sends requests to the backend app, which automatically includes the cookie. The backend swaps out the authentication cookie for the appropriate bearer token and forwards the request to the real API.

The big advantages of this approach are that no bearer tokens are ever sent to the browser, and much of the frontend code is significantly simplified. The main down side is that you need to run the additional backend service to support the frontend app. Nevertheless, this is quickly becoming the recommended approach. You can read more about the pattern in Duende's documentation at http://mng.bz/yQdB. Alternatively, you can find a project template for the BFF pattern from Damien Bowden at http://mng.bz/MBlW.

Bearer tokens don't have to have any particular value; they could be a completely random string, for example. However, the most common format and the format used by OpenID Connect is a JWT. JWTs (defined in https://www.rfc-editor.org/rfc/ rfc7519.xhtml) consist of three parts:

- *A JavaScript Object Notation (JSON) header* describing the token
- *A JSON payload* containing the claims